SOC 2 Compliance Master Table

Below is a clean, exam-ready **master reference table** summarizing SOC 2 compliance. It covers:

- Trust Services Criteria (TSC) overview
- Security Common Criteria (CC1–CC9) mapped to COSO 17 Principles
- Control types and examples
- Typical evidence auditors request

Table 1: Trust Services Criteria (TSC) Overview

TSC Category	Mandatory?	Core Focus	Typical When Included	Key Additional Criteria Refs
Security	Yes	Protection against unauthorized access, use, disclosure, etc.	Always (base of every SOC 2)	CC1–CC9
Availability	No	System uptime, capacity, backup & recovery	Cloud/SaaS with SLAs	A1.1–A1.3
Processing Integrity	No	Accurate, complete, timely processing	Financial processing, data services	PI1.1–PI1.5
Confidentiality	No	Protection of confidential information	Contracts with confidentiality clauses	C1.1–C1.2
Privacy	No	Handling of personal information (notice, consent, etc.)	Handles PII/PHI (GDPR, HIPAA overlap)	P1.0–P8.1

Table 2: Security Common Criteria (CC1–CC9) + COSO 17 Principles Mapping + Control Types

TSC Ref	COSO Principle	Description (Key Objective)	Control Type(s)	Key Examples / Policies	Typical A Evidence

CC1.1–CC1.5	1–5 (Control Environment)	Integrity, ethics, board oversight, structure, competence, accountability	Preventative + Administrative	Ethics/Code of Conduct, Security Policy, HR/Onboarding Policy, Termination User Policy	Signed po org chart minutes, records, backgrou checks
CC2.1–CC2.3	13–15 (Information & Communication)	Quality information, internal & external communication	Detective + Procedural	Communication plan, incident notification process	Meeting minutes, distributi external p notices
CC3.1–CC3.4	6–9 (Risk Assessment)	Objectives, risk identification, fraud, changes	Preventative + Detective	Risk assessment register, SLA commitments	Risk regis annual ris assessme fraud risk analysis
CC4.1–CC4.2	16–17 (Monitoring)	Ongoing/separate evaluations, deficiency communication	Detective	Internal audits, user access reviews, monitoring dashboards	Monitorin access re reports, deficienc remediati tracker
CC5.1–CC5.3	10–12 (Control Activities)	Control selection, technology general controls, policies/procedures	Preventative + Procedural	Change Management Policy, Segregation of Duties Policy	Policies, procedur evidence deployme
CC6.1–CC6.8	— (Logical & Physical Access)	Access provisioning, least privilege, SoD, physical security, malware protection	Preventative (mostly)	MFA, endpoint management, physical access logs, termination policy	Access request/a tickets, q access re offboardi checklist malware r
CC7.1–CC7.5	— (System Operations)	Vulnerability monitoring, incident response, recovery	Detective + Corrective	Incident Response Plan, Business Continuity/Disaster Recovery Plan	Incident l tabletop exercise r backup te reports

CC8.1	— (Change Management)	Authorize, test, approve, implement changes	Preventative	Change Management Policy (Dev/QA/Prod separation)	Change t with test evidence approval, separate implemen
CC9.1–CC9.2	— (Risk Mitigation)	Business disruption mitigation, vendor risk	Preventative	Vendor risk assessments, cyber insurance, BCP	Vendor questionn insurance certificat treatmen

Additional Criteria Tables (when scoped)

Availability (A1)

- A1.1 Capacity monitoring
- A1.2 Backup & recovery infrastructure
- A1.3 Recovery plan testing
  Evidence: SLA reports, backup logs, DR test results

Confidentiality (C1)

- C1.1 Identify & maintain confidential info
- C1.2 Secure disposal
  Evidence: Data classification policy, disposal logs

Processing Integrity (PI1)

- PI1.1–PI1.5 Input/output accuracy, completeness, timeliness
  Evidence: Reconciliation reports, processing logs

Privacy (P1–P8)

- Notice, consent, collection, use/retention/disposal, access, disclosure, quality, monitoring
  Evidence: Privacy policy, consent records, breach notification logs, DPA contracts

---

Detailed SOC 2 Notes (Comprehensive Reference)

1. What is SOC 2?

- Voluntary **attestation** (not certification) issued by a **CPA firm** (Service Auditor).
- Reports on **controls** relevant to **Trust Services Criteria** (TSC).
- Goal: Prove the organization's system is **safe, secure, and reliable** for customers.
- Two types:
  - **Type I** → Point-in-time (design & implementation "as of" a date)
  - **Type II** → Over a period (design + **operating effectiveness** over 3–12 months — most common & valuable)

2. Report Structure (Standard AICPA Format)

- **Section I** — Independent Service Auditor's Report (the opinion: unqualified/qualified/adverse)
- **Section II** — Management's Assertion
- **Section III** — **System Description** (also called "Description of the Service Organization's System") — management's responsibility
- **Section IV** — Tests of Controls & Results (auditor's work)

Section III is known as: System Description (correct answer).

3. COSO Framework (17 Principles)

SOC 2 Security (CC1–CC5) is built on the **COSO 2013 Internal Control Framework**:

- Control Environment (5 principles)
- Risk Assessment (4)
- Control Activities (3)
- Information & Communication (3)
- Monitoring Activities (2)

Principle 12 (CC5.3) is especially important: "The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action."

4. Control Types (Critical Distinction)

- **Preventative** — Stops bad things (e.g., approval gate before migration)
- **Detective** — Finds bad things (e.g., access review, monitoring alerts)
- **Corrective** — Fixes after detection (e.g., incident response, rollback)
- **Compensating** — Alternative when primary control is hard (e.g., extra monitoring when full SoD not possible)

5. Key Policies & Controls You Must Have

- Ethics / Code of Conduct
- Security Policy
- HR / Onboarding / Termination Policy
- User Access Review (quarterly/annual — covers **ALL** systems with user accounts)
- Change Management Policy (Dev/QA/Prod separation, ticketing, testing, approval, SoD)
- Incident Response Plan
- Business Continuity & Disaster Recovery Plan
- Data Classification & Asset Inventory
- Vendor / Sub-service Organization Management
- Endpoint Management & Anti-Malware

6. Onboarding Requirements (Must Cover All)

- Company overview training
- Role-specific training
- Security awareness training
- Access provisioning (least privilege)
  → **All of the above** is correct.

7. Change Management Best Practices (CC8.1)

- Formal policy + ticketing system

- Separate environments (Dev / QA / Prod)
- Developers cannot push to Prod without approval
- Testing + approval + SoD evidence
- Emergency change process defined
- Audit walkthrough + sample testing required

8. User Access Review (Minimum Scope)

All systems used by the organisation that have user accounts (not just email/IdP or critical systems).

9. Data Classification – Highest Protection

Personal health care information (PHI) requires the highest level (HIPAA-level safeguards).

10. Risk Rating Formula

Risk Rating = Impact × Likelihood (product, not sum or division).

11. Audit Lifecycle (Typical Sequence)

1. Gap analysis / readiness assessment
2. Select CPA firm
3. Define scope & System Description (Section III)
4. Implement & document controls
5. Evidence collection over period (Type II)
6. Audit fieldwork
7. Management representation letter (mandatory)
8. Draft → Final report + opinion
9. Post-audit: remediate, lessons learned, plan next cycle

Findings trend: Usually **more** in Year 1 (new controls). Year 2+ typically fewer or stable as maturity improves → "Companies tend to have more findings in the 2nd year" = **FALSE**.

12. Management Responsibilities

- Create System Description (Section III)
- Provide **Management Representation Letter** (mandatory document)
- Remediate findings
- Maintain controls year-round

13. Glossary (Key Terms)

- **Deviation** — exception/finding in testing
- **CUEC** — Complementary User Entity Controls
- **Sub-service organization** — carve-out or inclusive
- **CIA Triad** — Confidentiality, Integrity, Availability
- **SoD** — Segregation of Duties (e.g., developer cannot deploy own code)
- **Endpoint Management Tool** — Manage, monitor, detect non-compliance & alert on threats (TRUE statement)

14. Post-Report Actions (After Final Report)

- Internal recap: what went well / what didn't
- Remediate any findings
- Share report securely
- Plan next audit
- Continuous monitoring & automation

These notes + tables cover **every detail** from your dump (including all CC refs, Privacy P1–P8, Availability, Processing Integrity, audit steps, training lists, breach response, change management details, etc.). Use the tables for quick revision and the notes for deep understanding.

If you want this exported as a single Markdown file, Notion page, or expanded with sample evidence templates / policy skeletons, just say the word! You now have a complete, professional SOC 2 study & implementation blueprint. Good luck with the exam and your compliance journey! 🚀